

Руководство пользователя

CommitScope

2.4.0 / Подготовьте доверенную установку

Используйте проверенную копию CommitScope отдельно от приложения. Поддерживаются macOS и glibc Linux, x86_64/ARM64, Python 3.11-3.14. Нативная Windows вне области поддержки; используйте поддерживаемый Linux в WSL2. Нужны Git, venv/pip, корневые сертификаты и разрешенный исходящий HTTPS.

Эта копия не заявляет наличие публичного тега или релиза v2.4.0. Установите точную проверенную ревизию. Bootstrap скачивает закрепленные сканеры и базы, но не устанавливает зависимости цели и не исполняет ее.

```
pipx install /absolute/path/to/commitscope
commitscope preflight
commitscope bootstrap
commitscope doctor
```

Войдите в нужный аккаунт

Установите официальный Claude Code CLI из доверенной копии и войдите от того же непривилегированного пользователя ОС, который будет запускать проверку. Корпоративный режим поддерживает только аккаунт. Устраните API-ключи, маршрутизацию провайдера, переопределения модели и профиля в окружении: команда отклоняет их и не переключается на API или другого провайдера.

```
sh scripts/install-claude.sh
claude auth login
claude auth status
```

Выберите коммит, политику и хранилище

Закоммитьте или уберите в stash все изменения цели, включая неотслеживаемые файлы. Нужен полный ID коммита: 40 или 64 символа в нижнем регистре. Изучите `examples/review-policy.json` и разместите утвержденную политику вне цели.

Выберите новый выходной каталог вне цели. Его существующий родитель должен принадлежать текущему пользователю или root и не разрешать запись группе или всем. Символические ссылки и существующий выходной каталог отклоняются.

```
git -C /absolute/path/to/application status --short
git -C /absolute/path/to/application rev-parse HEAD
```

Запустите одну проверку

Все пять этапов обязательны

Semgrep, Gitleaks и Trivy должны завершиться. Hunter и Verifier обязательны для завершения корпоративной проверки. Команда работает с неизменяемым снимком и записывает манифест последним. Укажите точный ID модели, утвержденный организацией; псевдонимы вроде sonnet отклоняются.

Ниже показан формат команды. Замените пути, ID коммита и APPROVED_EXACT_MODEL_ID проверенными значениями. --allow-code-upload явно разрешает передачу ограниченного отобранного пакета исходников в Anthropic. Отбор не гарантирует полного удаления секретов.

```
commitscope review \  
--repo /absolute/path/to/application \  
--ref 0123456789abcdef0123456789abcdef01234567 \  
--policy /protected/review-policy.json \  
--out /protected/reviews/run-id \  
--auth account \  
--allow-code-upload \  
--model APPROVED_EXACT_MODEL_ID
```

Строгий учет зависимостей

Инвентаризация зависимостей по умолчанию строгая. Только для проверенной цели со стандартной библиотекой добавьте --allow-empty-sca с обоснованием владельца после изучения импортов и метаданных сборки. Причина сохраняется как материал, но не удостоверяется независимо и не позволяет игнорировать отсутствующий lock-файл.

Сбой входа, исчерпанная квота, недоступная модель, сетевой сбой, тайм-аут, неверный формат ответа или неполное покрытие сканеров либо ИИ дают INCOMPLETE. Сохраните неудачный запуск, устраните причину и начните новый.

Прочитайте состояние и код возврата

READY_FOR_HUMAN_REVIEW / 0: обязательные этапы завершены, нормализованных находок на пороге политики нет. Сохраните и передайте запуск человеку для решения.

FINDINGS_REQUIRE_TRIAGE / 1: этапы завершены, находки достигают порога. Сохраните и передайте материалы для разбора.

INCOMPLETE / 2: не выполнена предпосылка, этап или обязательная проверка. Корпоративная проверка не завершена.

READY_FOR_HUMAN_REVIEW не разрешает слияние и не утверждает, что приложение безопасно.

Передайте и перепроверьте

Защитите и проверьте исходный запуск

Передайте неизменный конфиденциальный каталог назначенному ревьюеру через защищенное хранилище. Передавайте нормализованные отчеты и evidence/ только по правилам компании. Пакеты исходников, сырой вывод сканеров, ответы моделей и диагностику из private/ нельзя публиковать или коммитить.

```
commitscope verify-review --run /protected/reviews/run-id
```

Понимайте границы проверки

verify-review проверяет точную структуру артефактов, безопасные типы и права, хеши, идентичность коммита и снимка, хеши политики и ресурсов, завершение сканеров, покрытие Hunter/Verifier и согласованность решения. Для корректных материалов возвращается записанный код 0 или 1; для измененных, отсутствующих, противоречивых или неполных - INCOMPLETE / 2.

Манифест не подписан: авторство и неизменность хранения не проверяются криптографически. Изучите материалы и заполните копию reviewer-decision-template.json в защищенной системе решений с проверенным хешем манифеста. Личность и одобрение контролируются вне инструмента.

Каждый новый коммит требует нового запуска

После исправления используйте новый коммит и новый каталог. Повторите сканеры, Hunter, Verifier, проверку манифеста и разбор человеком. Сохраняйте прежние материалы без изменений. Исчезновение находки в compare не доказывает исправление.

Частичная диагностика не завершает приемку

GitHub Action и готовые CI-процессы запускают только сканеры. Они не выполняют обязательный локальный процесс Hunter/Verifier. Не загружайте private/ и не передавайте CI личный вход Claude.

SCANNERS_VERIFIED_AI_NOT_RUN не означает завершенную корпоративную проверку. Это результат приемки только сканеров. Команды совместимости commitscope scan и commitscope ai, даже последовательно, не заменяют commitscope review.

Модульные тесты и документы не доказывают готовность к эксплуатации. Отдельно проверьте поддерживаемые хосты, реальные сканеры и явно разрешенные запуски Hunter/Verifier на контролируемых примерах. Ссылки: START-HERE.md и docs/VERIFICATION.md. Из доверенной копии: `python3 -I review.py <command>`.